Aran Learn 31: Name Registries, Field Evidence and Security Headers

Who: everyone (Bharadhwaj and Arun for sections 1 to 3, Aasif for section 4). **Time:** about 20 minutes. **Read before:** changing how names or addresses are detected, or the headers a bank page sends.

1. Why a model alone misses names

Aran finds names and addresses with a CRF model (Learn 5). A model learns what names *usually* look like: a capital letter, a cue word such as “customer” before it. So it scores `SUNITA REDDY` (all capitals) low, it can miss a name inside JSON (`{"applicant": "Divya Reddy"}`), and it can cut an address into pieces such as “Kamarajar Salai” and “Civil Lines”, one of which falls under the sink’s threshold and goes out raw.

2. The bank already knows its customers’ names

The same idea as the number registry (Learn 4): the bank holds a list of its customers. Aran stores a **keyed hash** (HMAC) of each name, lower-cased with spaces tidied, in the cuckoo filter. It never stores the name itself.

When a line holds two to four capitalised words in a row, Aran hashes them and asks the filter. A hit is very strong evidence (the odds are multiplied by about one over the filter’s false-positive rate), so the name is tokenised even if the model gave it 5%. Because the hash is taken on the lower-case form, `Sunita Reddy`, `SUNITA REDDY` and `sunita  reddy` all match.

When a customer is erased (DPDP), their name is removed from the filter along with their numbers.

Try it:

```
from firewall.registry import canonical
canonical("PER", "SUNITA   Reddy")   # 'sunita reddy'
```

3. A field name is evidence too

`"applicant": "..."`, `customer=...`, `addr="..."`: the field name says what the value is. Aran now takes the **whole value** of a name or address field as one finding and multiplies its odds by 500. One whole-address finding beats the model’s fragments, so nothing is left in between. Two guards stop false alarms: a name value must be two to five words that each start with a capital (so `name=nginx` and `customer=CUST-0001` are skipped), and an address value must be at least 8 characters. A free-text address after a cue word that ends in a 6-digit PIN is also taken whole.

What this does **not** fix: a stranger’s name in free text with no cue and no registry hit. That still needs a stronger model (roadmap item 7, GLiNER).

4. Security headers on a web page

A **Content Security Policy** (CSP) is a header that tells the browser where a page may load things from. If an attacker manages to put `<script>` into a customer name, a CSP of `script-src 'self'` stops the browser running it. The banks now send:

Header	What it does
`script-src 'self'`	Scripts only from this server, no inline scripts
`connect-src ...`	Which servers the page may call (this bank, the other bank, Aran Cloud, localhost ports)
`frame-src` and `frame-ancestors`	The side-by-side page shows both banks in frames, so the banks may frame each other and nobody else may frame them
`object-src 'none'`	No plugins
`X-Content-Type-Options: nosniff`	The browser must trust the declared file type
`Permissions-Policy`	No camera, microphone or location for the banks

To check a page: open it, then DevTools, Console. A blocked load shows as a red “violates the following Content Security Policy” line. That is how the frame problem was found and fixed before it shipped.

5. Quick check

1. Why does a lower-case hash let Aran catch a name in capitals?
2. Why must a name be removed from the registry when the customer is erased?
3. Why is `name=nginx` not taken as a person?
4. What would happen to the side-by-side page if `frame-ancestors` were only `'self'`?